SIMATS ENGINEERING

CSA6303- Threat Intelligence and Network Security

A1-Threat Intelligence Report

Assessment Questions

Subject	Threat Intelligence	**Total Marks**	50
Questions	10 (all compulsory)	**Marks per Question**	5
REg.No	192425380	**Name**	T. Bhanu Pavan Varma
Faculty	Dr.V.Parthipan	**Slot**	A

Instructions: Answer all questions. Each question carries 5 marks. Support answers with examples and diagrams where appropriate.

Code of Conduct:

I T. Bhanu Pavan Varma(192425380) (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.



Signature of Student

Questions

Q1. Malware [5 Marks]

Define malware and explain any four types of malware (virus, worm, trojan, ransomware, spyware). For each type, state how it spreads and one impact on the victim.

Q2. Phishing [5 Marks]

Describe how a phishing attack is carried out. Differentiate between spear phishing, whaling and vishing, and list three measures an organisation can adopt to reduce phishing risk.

Q3. DoS and DDoS [5 Marks]

Distinguish between a Denial of Service (DoS) attack and a Distributed Denial of Service (DDoS) attack. Explain the working of a SYN flood and outline two mitigation techniques.

Q4. Man-in-the-Middle Attacks [5 Marks]

What is a Man-in-the-Middle (MITM) attack? Explain two techniques used to carry it out (for example ARP poisoning, rogue Wi-Fi access point, SSL stripping) and state how encryption helps defend against it.

Q5. Spoofing and Sniffing [5 Marks]

Compare spoofing and sniffing. Explain IP spoofing and ARP spoofing with an example each, and describe how packet sniffers such as Wireshark can be used both maliciously and legitimately.

Q6. Vulnerability Assessment [5 Marks]

Explain the vulnerability assessment process. Describe its main phases, and differentiate between vulnerability assessment and penetration testing. Name two commonly used scanning tools.

Q7. Vulnerability Scoring [5 Marks]

What are CVE and CVSS? Explain how CVSS scores help in prioritising vulnerabilities and why a high CVSS score alone may not decide the order of patching.

Q8. Threat Data Sources and OSINT [5 Marks]

Discuss the main sources of threat data (internal, external, open-source and commercial). Define Open-Source Intelligence (OSINT) and describe three OSINT sources or tools used in threat intelligence gathering.

Q9. Indicators of Compromise (IoCs) [5 Marks]

What are Indicators of Compromise (IoCs)? Classify them into network-based, host-based and file-based indicators with two examples of each, and explain how a security team uses IoCs during incident response.

Q10. Threat Feeds [5 Marks]

Explain what a threat intelligence feed is. Describe the common feed formats and sharing standards (STIX/TAXII), list two advantages and two limitations of using threat feeds, and name two example feeds.

Q1. Malware (5 Marks)

Definition: Malware (malicious software) is software designed to damage systems, steal information, disrupt operations, or gain unauthorized access.

Type	How it spreads	Impact
Virus	Attaches to files or programs and spreads when they are executed or shared.	Corrupts or damages files.
Worm	Self-replicates and spreads across networks by exploiting vulnerabilities.	Consumes bandwidth and slows networks.
Trojan	Disguises itself as legitimate software and is installed by a user.	Creates unauthorized access to a system.
Ransomware	Spreads through phishing emails, malicious downloads, or exploited vulnerabilities.	Encrypts files and demands ransom.
Spyware	Enters through malicious downloads, bundled software, or exploits.	Steals personal information and monitors user activity.

Q2. Phishing (5 Marks)

Phishing is a social engineering attack in which attackers impersonate trusted organizations or individuals to steal sensitive information.

How a phishing attack works

1. The attacker sends a fake email, message, or link.
2. The victim clicks the link or opens an attachment.
3. A fake website or malicious program collects information.
4. The attacker steals credentials or gains unauthorized access.

Types of phishing

Type	Explanation
Spear phishing	Targets a specific person or organization using personalized messages.
Whaling	Targets senior executives, such as CEOs and CFOs.
Vishing	Uses voice calls to trick victims into revealing sensitive information.

Three prevention measures

1. Conduct regular cybersecurity awareness training.
2. Use email filtering and anti-phishing tools.
3. Enable multi-factor authentication (MFA).

Q3. DoS and DDoS (5 Marks)

DoS (Denial of Service): An attack that overwhelms a system or service, making it unavailable to legitimate users, typically from a single source.

DDoS (Distributed Denial of Service): An attack that uses multiple compromised devices to overwhelm a target.

DoS	DDoS
Usually originates from one source.	Originates from multiple sources.
Easier to trace and block in some cases.	Harder to mitigate because traffic comes from many sources.

Working of a SYN flood

1. The attacker sends many TCP SYN requests to a server.
2. The server responds with SYN-ACK and waits for the final ACK.
3. The attacker leaves many connections incomplete.
4. Server resources become exhausted, preventing legitimate connections.

Two mitigation techniques

1. SYN cookies: Reduce resource consumption from incomplete TCP connections.
2. Firewall and DDoS protection: Filter suspicious traffic and distribute or absorb attack traffic.

Q4. Man-in-the-Middle (MITM) Attacks (5 Marks)

Definition: A MITM attack occurs when an attacker intercepts communication between two parties and may read or modify the information exchanged.

Two techniques

1. ARP poisoning

- The attacker sends forged ARP messages on a local network.
- The victim may associate the attacker's MAC address with the gateway's IP address.
- The attacker can intercept traffic.

2. Rogue Wi-Fi access point

- The attacker creates a fake Wi-Fi hotspot that appears trustworthy.
- A victim connects to it and sends network traffic through the attacker's device.
- Sensitive information may be exposed if communication is not properly protected.

Role of encryption

- HTTPS/TLS encrypts data in transit and helps prevent unauthorized reading or modification.
- Certificate validation helps users identify legitimate servers.
- VPNs can add protection on untrusted networks.

Q5. Spoofing and Sniffing (5 Marks)

Spoofing: Forging identity information to impersonate a trusted device or source.

Sniffing: Capturing and analyzing network packets transmitted over a network.

Difference

Spoofing	Sniffing
Falsifies identity information.	Captures network traffic.
May redirect or deceive communication.	May expose sensitive information.
Example: IP spoofing.	Example: Capturing unencrypted packets.

Types of spoofing

1. IP spoofing: An attacker forges the source IP address in packets to make them appear to come from another system.

Example: Forged source IP addresses are used in a DoS attack.

2. ARP spoofing: An attacker sends forged ARP messages to associate their MAC address with another device's IP address.

Example: A victim's device sends traffic intended for the gateway to the attacker's machine.

Packet sniffers — Wireshark

- Malicious use: Capturing unencrypted credentials or confidential information without permission.
- Legitimate use: Troubleshooting network problems, analyzing protocols, and investigating security incidents.

Q6. Vulnerability Assessment (5 Marks)

Definition: Vulnerability assessment is the systematic process of identifying, evaluating, and prioritizing security weaknesses in systems, networks, and applications.

Main phases

1. Planning and scope: Identify systems and define assessment objectives.
2. Scanning: Discover hosts, services, and potential vulnerabilities.
3. Analysis: Validate findings and assess severity.

4. Prioritization: Rank vulnerabilities according to risk.
5. Remediation and verification: Fix weaknesses and rescan to confirm corrections.

Vulnerability assessment vs. penetration testing

Vulnerability Assessment	Penetration Testing
Identifies and prioritizes weaknesses.	Attempts controlled exploitation to demonstrate risk.
Often covers many systems broadly.	Tests selected targets in greater depth.
Focuses on finding vulnerabilities.	Focuses on validating exploitability and impact.

Two scanning tools: Nessus and OpenVAS.

Q7. Vulnerability Scoring (5 Marks)

CVE (Common Vulnerabilities and Exposures): A standardized identifier assigned to a publicly disclosed cybersecurity vulnerability.

CVSS (Common Vulnerability Scoring System): A standard framework for rating vulnerability severity, generally on a scale from 0.0 to 10.0.

CVSS severity ranges

Score	Severity
0.0	None
0.1–3.9	Low
4.0–6.9	Medium
7.0–8.9	High
9.0–10.0	Critical

How CVSS helps

- Helps compare vulnerabilities by severity.
- Supports prioritization of patching and remediation.
- Highlights factors such as exploit complexity and potential impact.

Why a high CVSS score alone is insufficient: Patching priority also depends on active exploitation, asset importance, exposure to the internet, available mitigations, and business impact. A lower-scoring vulnerability actively exploited on a critical server may require faster action.

Q8. Threat Data Sources and OSINT (5 Marks)

Main threat data sources

Source	Description	Example
Internal	Data generated within an organization.	Firewall logs, IDS alerts, endpoint logs.
External	Information from outside organizations.	Security advisories, incident reports.
Open-source	Publicly available security information.	Public vulnerability databases, research blogs.
Commercial	Paid threat intelligence services.	Subscription-based threat feeds.

OSINT (Open-Source Intelligence) is the process of collecting and analyzing publicly available information to produce useful intelligence.

Three OSINT sources or tools

1. Shodan: Finds internet-connected devices and exposed services.
2. VirusTotal: Analyzes files, URLs, and domains using multiple security engines and threat data.
3. WHOIS: Provides domain registration information where available.

These sources help analysts investigate suspicious infrastructure, domains, and potential threats.

Q9. Indicators of Compromise (IoCs) (5 Marks)

Definition: Indicators of Compromise (IoCs) are observable signs that may indicate a system or network has been compromised.

Classification of IoCs

Category	Examples
Network-based	Suspicious IP address; malicious domain name.
Host-based	Unexpected registry modification; suspicious process execution.
File-based	Known malicious file hash; suspicious executable file.

Uses during incident response

1. Detection: Search logs and security tools for matching indicators.
2. Investigation: Identify potentially compromised systems and related activity.
3. Containment: Block malicious IPs or domains and isolate affected endpoints.
4. Eradication and recovery: Remove malware, remediate weaknesses, and restore systems.
5. Monitoring: Continue checking for related indicators.

Note: An IoC is a clue, not always proof of compromise. Analysts should validate findings and consider context.

Q10. Threat Feeds (5 Marks)

Definition: A threat intelligence feed is a regularly updated stream of information about known or emerging cyber threats, such as malicious IP addresses, domains, file hashes, and attacker techniques.

Common feed formats and standards

- CSV: Stores threat indicators in tabular form.
- JSON: Represents threat information in a structured format.
- STIX (Structured Threat Information Expression): A standardized language for describing and sharing cyber threat intelligence.
- TAXII (Trusted Automated Exchange of Intelligence Information): A protocol for exchanging threat intelligence, commonly STIX data, between systems.

Advantages

1. Provides timely information about emerging threats.
2. Supports automated detection and blocking through security tools.

Limitations

1. Feeds may contain false positives or outdated indicators.
2. Integration, maintenance, and commercial subscriptions may be costly.

Two example threat feeds

1. AlienVault OTX (Open Threat Exchange) — community threat intelligence and indicator sharing.

2. abuse.ch URLhaus — shares information about URLs associated with malware distribution.

Marking Scheme (for evaluator)

Q.No	Expected points and mark distribution (total 5)
1	Definition (1); four types with spread method and impact (4 x 1 = 4).
2	Attack flow (1.5); three variants differentiated (1.5); three countermeasures (2).
3	DoS vs DDoS (1.5); SYN flood working (1.5); two mitigations such as rate limiting, SYN cookies, CDN/scrubbing, blackhole routing (2).
4	Definition and interception concept (1); two techniques (2); defences such as TLS, HSTS, certificate validation, VPN (2).
5	Comparison (1); IP and ARP spoofing with examples (2); sniffer dual use (1.5); one countermeasure (0.5).
6	Phases: asset discovery, scanning, analysis and prioritisation, reporting, remediation (2); VA vs pen test (2); two tools such as Nessus, OpenVAS, Qualys (1).
7	CVE meaning (1); CVSS meaning and severity ratings (1.5); role in prioritisation (1.5); context factors such as exploitability and asset criticality (1).
8	Threat data source categories (2); OSINT definition (1); three OSINT sources or tools such as Shodan, VirusTotal, WHOIS, social media, dark web monitoring (2).
9	Definition (1); classification with examples (3); use in detection and response (1).
10	Definition (1); STIX/TAXII or similar formats (1.5); two advantages and two limitations (2); two example feeds such as AlienVault OTX, MISP, abuse.ch (0.5).